

Project: Analysing a Phishing Email

Prepared by Mallikah Sharp

Case Study: Phishing attempt from Rackspace Hosting RACKS-8-NET-10 (NET-198-61-128-0-1) 198.61.128.0 - 198.61.255.255 Mailgun Technologies Inc MNO87-198-61-254-0-0 (NET-198-61-254-0-1) 198.61.254.0 - 198.61.255.255, posing as Ripple (XRP).

Tools used:

- Github
- Sandboxed Kali Linux VM using VirtualBox VM manager
- Encryptomatic Mail viewer
- mxtoolbox (dnslookup)
- spf-record
- Whois
- virustotal

Resources:

- Github link to the raw email information: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-1007.eml

Introduction

The team at "phishing@pot" received an email from a domain claiming to be a part of Ripple's (XRP) support team. Ripple is an online platform that sells, trades and distributes digital assets like cryptocurrency and NFTs. Many users can use the site to purchase and sell digital assets with a built-in wallet, or they can link their accounts to their personal cryptocurrency wallets.

There are 3 things that could have happened here:

1. The attacker has compromised Mailgun's email server and is sending emails from there. Possible but very unlikely, especially as they're posing as an unrelated company. If you were to go to the effort of compromising an email server, you would pretend to be said company as it will appear more legitimate

2. The IP address was never registered. Although Mailgun have registered the range of 198.61.254.0 - 198.61.255.255, there are many IP addresses in here. It is possible they may have never actually used this one, so someone else just went and registered it.

3. The IP was owned by Mailgun, but it expired and so a phisher bought it. This is very common, as that would have been a 'well behaved' IP address with lots of legitimate use. Using it to send phish emails vs buying a brand new one that has no history, has benefits in getting past some security controls that work on reputation checks of IP addresses. We needed to confirm whether it is malicious or benign, educate a company/user on this type of phish attempt, take action to report this IP address to the domain host to get it taken down.

An analysis of both the **header** and the **body** of the email was conducted to detect and verify red flags commonly found in modern phishing campaigns.

Headers are the metadata that accompanies email, and include timestamps, routing data, sender/receiver information and other technical details. The **Body** is the main text associated with the message being sent in the email, including attachments and pictures included in the message.

Good news and rewards for the XRP Community

From:	Ripple <xrpl@isarops.com>
To:	phishing@pot
Sent time:	27 Jul, 2023 8:23:11 AM



XRP Token Allocation and Onboarding Program starting Today

Ripple's Landmark Victory in the SEC Lawsuit has enabled the Foundation to share out its reserve XRP tokens to individual investors, pre-mine buyers, holders

and even those just starting and funding new accounts.

Head on and read all the required info and program details on our latest [blog post](#).

15 to 30% more XRP instantly added to your account balance

With a guaranteed boost of 15% additional tokens on top of the funding balance, increasing and topping up at 30% for the most experienced XRPL users, this 30-day limited offering will definitely bring more growth to our ecosystem while also boosting usage.

Allocations are based on every account recorded details, such as age, transactional activity, trading, trust line interaction, NFT involvement (minting, storing, or trading) and overall network participation.

Register and submit your claim with the Token Allocation Tool

Access the [Allocation Tool](#), connect to RippleNet, verify your account address, estimate your reward, submit the token claim and receive your share instantly.

Register

Phishing Email Body Analysis

The analysis of the email reveals the follow red flags which could indicate a potential phishing scheme:

- **Unfamiliar and unusual email address:** this is not a known sender.
 - Actual domain of email: **isarops.com**
- **Urgent or alarming language:** The email creates a sense of urgency by offering a cryptocurrency 15-30% more added to the account balance today. This is meant to lure potential victims by creating financial pressure.
- **Suspicious attachments or links:** The link to access the "Allocation Tool" is suspicious. As well as the "blog post" link.
- **"Too good to be true" offer** – Promises of gifting **15-30% more XRP** into the account is unrealistic and should be treated with suspicion.
- **Lack of company branding:** This email included a Ripple logo but not much other company branding.
- **No signature or contact information:** No contact card or information, including no direct link to the actual Ripple (XRP) domain, or the real support team at the email domain **isarops.com**. No personal signature from an employee or representative.

Phishing Email Header Analysis

- **"From" Address**
 - From: "Ripple" xrpl@isarops.com
- **"Reply-To" Address**
 - Reply-To: "Ripple" xrpl@isarops.com This name is the same which will make unassuming targets believe to be legitimate.
- **"Received" Fields**
 - The email passed through multiple legitimate Microsoft Outlook servers, but the key IP address in the chain belongs to

198.61.254.42, which is registered to Mailgun Technologies, Inc., hosted by Rackspace, which is not the same as Ripple. This domain appears to be part of a phishing training tool (Phishing_Pot), as mentioned in the **Phishing Pot** header.

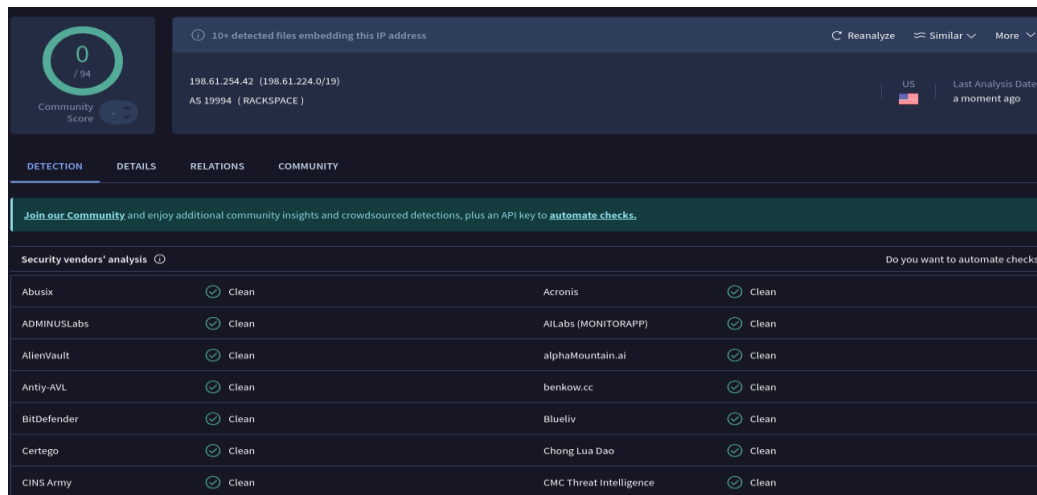
Headers Found

Header Name	Header Value
Authentication-Results	spl=pass (sender IP is 198.61.254.42) smtp.mailfrom=xisarops.com; dkim=pass (signature was verified) header.d=xisarops.com;dmarc=pass action=none header.from=xisarops.com;compauth=pass reason=100
Received-SPF	Pass (protection.outlook.com: domain of isarops.com designates 198.61.254.42 as permitted sender) receiver=protection.outlook.com; client-ip=198.61.254.42; helo=s254-42.mailgun.net; pr=C
X-IncomingTopHeaderMarker	OriginalChecksum:80A5F77032CEFE77F0C4F98812D23A05291E8B2F0D38C3FE5F973A38638EFA,UpperCasedChecksum:D4E7D8FA0C663C4C77F1F85C6EBB7BEECEE13698BA074AD00F4449EC5561C25,SizeAsReceived:1092,Count:14
DKIM-Signature	a=rsa-sha256,v=1,c=relaxed/relaxed,d=xisarops.com,q=dns/bt,s=k1,t=1690453391,z=Content-Type: Content-Transfer-Encoding: Message-Id: To: To: From: From: Subject: Subject: Mime-Version: Date: Sender: Sender; bh=ds41OIZYDEJODdyBZ5155Cemip5PQnBDV+EqLkx; b=ClyYq8ZRh1urifT3DahY8T5BWWyIU8+spF+uOfgZYXkoELz0guk8SeLzMAGuZmC8eggsJd18PYkVcG+cOp6owQZjzth8NymQmZ1VQemwPQd0X05wQTVY2MayClq4vbu2jLcXfXCerpdaHgHwWalGne2Ys=
X-Mailgun-Sending-Ip	198.61.254.42
X-Mailgun-Sid	WYjZWJzMIshJuZHp228Zi1wQGhvdG1haWwUY29tflwOTEyNDMyf0=
Sender	xrpl@isarops.com
Date	Thu, 27 Jul 2023 08:23:11 +0000
Subject	Good news and rewards for the XRP Community
From	Ripple <xrpl@isarops.com>
To	phishing@pot
X-Mailgun-Track	false
Message-Id	<20230727082311.9d0c426cad4b43c@xisarops.com>
Content-Transfer-Encoding	quoted-printable
Content-Type	text/html; charset="utf-8"
X-IncomingHeaderCount	14
Return-Path	bounce-5384b0.912432.phishing@pot-hotmail.com@isarops.com
X-MS-Exchange-Organization-ExpirationStartTime	27 Jul 2023 08:23:11.7629 (UTC)

[illegible]

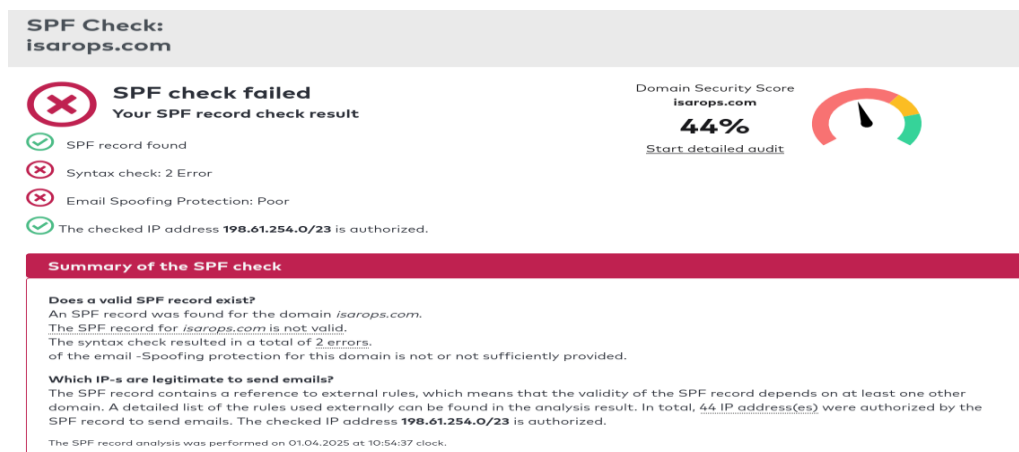
- **IP Address and Domain Reputation**

- **198.61.254.42**: This IP belongs to the USA. We used a tool like **MXToolbox** or **IPVoid** to check if this IP has any history of being associated with malicious activity.
- : This domain is explicitly mentioned as related to phishing training.



- **SPF Record**

- **SPF**: The email failed SPF checks because **isarops.com** is listed as an authorised sender for the domain. IP **198.61.254.42** is not authorised to send emails on this domain.



- **DKIM Signature**

- **DKIM**: The email did not pass DKIM checks with a valid signature from tacklephishing.com, confirming that the email has not been altered in transit and was sent by an authorised server for that domain.

The screenshot shows the MXToolbox SuperTool interface. At the top, the 'Analyze Headers' tab is selected. Below the navigation bar, the header 'Header Analyzed' is displayed with the email subject 'Good news and rewards for the XRP Community'. A yellow warning box states: 'Copy/Paste Warning: Copy/Pasting a header works for most people, but sometimes it can cause problems with things like DKIM Validation. For the best results, use our Email Deliverability tool'. Under the 'Delivery Information' section, a list of checks is shown: DMARC Compliant (green), SPF Alignment (green), SPF Authenticated (green), DKIM Alignment (green), and DKIM Authenticated (red with an X icon).

Check	Status
DMARC Compliant	Pass
SPF Alignment	Pass
SPF Authenticated	Pass
DKIM Alignment	Pass
DKIM Authenticated	Fail

- **DMARC Authentication**
 - **DMARC:** The **DMARC** checks compliant with a green status. This means there was no issue with alignment or policy enforcement for this email, which is **not a red flag**.
- **Message-ID**
 - **Message-ID:** **20230727082311.9d0b426cad4b843b@isarops.com**
 - The unique message ID seems valid and specific, so there's no obvious manipulation here.
- **Subject Encoding and Language**
 - **Subject:** "Good news and rewards for the XRP Community"
 - The subject seems generic but not suspicious by itself. There are no encoding issues or strange characters here, but the content could be social engineering.
- **MIME-Version 1.0**
 - The MIME-Version field looks typical for HTML-formatted emails, with no obvious manipulation.

Conclusion:

Phishing likelihood: High. The domain **failed DKIM** check, and redirection to a suspicious domain are significant indicators of phishing. Additionally, the "From" and "Reply-To" addresses were the same from the "Received" section, but it still raises suspicion that the email may have been spoofed or manipulated. However, the **DMARC passed** as a green flag which may make this a more deadly attack and could have gotten into the end users inbox. The addition of malicious links linking personal crypto account information and the changing of the Return-Path to redirect responses to the hacker's email are all clear indicators of a phishing campaign.